

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)
-

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations:

Controls recommendations

Least privilege

Implement role-based access control (RBAC) so employees only have access to the systems and data needed for their job function. Without this, a compromised low-level account (or an insider) can move laterally into sensitive systems like customer PII or financial records. Priority: High.

Separation of duties

Split high-risk processes (e.g., someone who approves payments shouldn't also be able to issue them) across multiple people or roles. This reduces fraud risk and single points of failure.

Password policies + password management system

Enforce minimum complexity, rotation, and MFA, and deploy an enterprise password manager. Weak/reused passwords are one of the most common initial attack vectors (credential stuffing, brute force).

Disaster recovery plan + backups

Establish a documented DR plan with defined RTO/RPO, and implement regular, tested, encrypted, offsite/cloud backups. Right now, ransomware or hardware failure could cause irrecoverable data loss and prolonged downtime — a major business continuity risk.

Firewall + IDS

Deploy a firewall to filter untrusted traffic and an intrusion detection system to flag anomalous/malicious activity in real time. Without these, the network has no perimeter defense or early-warning capability against intrusions.

Antivirus/anti-malware

Deploy endpoint protection across all workstations and servers, with automatic signature updates and centralized monitoring.

Manual monitoring for legacy systems

If legacy systems can't be patched or replaced immediately, ensure dedicated staff time is allocated to monitor logs and anomalies manually until systems are upgraded or retired. Flag this as a known residual risk in the risk register.

Encryption

Encrypt sensitive data both at rest and in transit (especially cardholder data and customer PII), using industry-standard protocols (AES-256, TLS 1.2+).

Physical controls (locks, CCTV, fire detection)

Install commercial-grade locks on server rooms/storage areas, CCTV covering entry points and sensitive areas, and fire suppression/detection systems. Physical breaches or disasters (fire, theft) can compromise data and hardware just as easily as cyberattacks — often overlooked in a purely "cyber" risk assessment.

Compliance recommendations

PCI DSS

Restrict credit card data access strictly to authorized personnel (ties to least privilege above).

Store/process/transmit cardholder data only within a segmented, secured environment (consider tokenization or a PCI-compliant third-party processor to reduce scope entirely).

Encrypt all cardholder data in transit and at rest.

Enforce strong password/MFA policies for any system touching payment data.

Risk if not addressed: fines, loss of ability to process card payments, reputational damage, and liability for breach costs.

GDPR

Implement technical and organizational measures to secure EU customer data (encryption, access controls, anonymization where feasible).

Build and test a 72-hour breach notification process/workflow now, before an incident — this is a hard regulatory deadline, not a best-effort target.

Complete a data inventory/classification exercise so you know what personal data exists, where it lives, and its sensitivity level.

Formalize privacy policies and data retention/processing procedures, and make sure they're actually operational, not just documented.

Risk if not addressed: significant fines (up to 4% of global annual revenue or €20M, whichever is greater), and legal exposure in the EU market.

SOC 2 (Type 1/2)

Establish formal, documented user access policies (provisioning, review, deprovisioning).

Ensure confidentiality of PII/SPII through access controls and encryption.

Implement data integrity controls — validation, checksums, audit trails — to ensure data isn't altered improperly.

Ensure availability through redundancy, backups, and DR planning (ties back to earlier recommendation).

Risk if not addressed: inability to pass a SOC 2 audit, which is often a hard requirement for B2B customers/partners doing due diligence on Botium Toys.

Suggested prioritization for the IT manager

Immediate (0–30 days): MFA/password policy, backups, basic firewall/AV if not present, breach notification workflow draft.

Short-term (1–3 months): RBAC/least privilege, encryption rollout, IDS, physical security upgrades.

Medium-term (3–6 months): Full DR plan and testing, data classification/inventory, SOC 2 readiness gap analysis, legacy system remediation or replacement plan.